

비밀정보 관리 완료 보고서

Secret 저장·주입·교체·폐기와 사고 대응 운영 기준

VALIDATED · 15 CONTROLS PASS · SECRET LEAKS 0 · REBOOT RECOVERY PASS

항목	값
GitHub Issue	#15 비밀정보 관리 방식 결정
검증일	2026-07-31
보호 저장소	/etc/ablestack-techflow/secrets/activepieces.env
소유권·권한	root:ablecloud 0640 · 상위 디렉터리 0750
상태	VALIDATED

이 문서에는 계정 비밀번호, API Key, HMAC Secret과 서버의 실제 Secret 값이 포함되지 않는다.

1. 결과 요약

Issue #15 완료 기준인 비노출 저장, 런타임 주입, 접근 권한, 교체·폐기, 감사와 사고 대응을 모두 충족했다.

영역	적용	판정
저장	/etc 보호 파일과 배포 Symlink	PASS
접근	root:ablecloud 0640 · 디렉터리 0750	PASS
Webhook 교체	Current + Previous Grace Period	PASS
폐기	현재 202 · 폐기된 직전 값 401	PASS
영향 제한	Event Gateway만 재생성 · Redis 유지	PASS
감사	값 없는 JSONL 변경 Event	PASS
노출 검사	배포 자산·컨테이너 로그	0건
복구	서비스 재시작·호스트 재부팅	PASS

제품 경계

- 단일 서버 파일 저장소는 사내 실증 기준이다.
- 고객 제품은 TechFlow Secret Provider 뒤에 Vault, KMS 또는 배포 플랫폼 Secret 저장소를 연결한다.
- 고객 공개 여부는 제품 책임자의 별도 결정이며 구현 완료 기준과 분리한다.

2. Secret 분류와 책임

분류	대표 값	교체 원칙
S1	AP_ENCRYPTION_KEY	migration-and-recovery-plan-required
S2	AP_JWT_SECRET · AP_API_KEY	maintenance-window-and-session-invalidation
S3	PostgreSQL credential · Redis credential	coordinated-store-change-and-dependent-service-restart
S4	TECHFLOW_WEBHOOK_SECRET	current-previous-grace-period-then-revoke
S5	GitHub · AI provider · Community · Messenger	provider-issue-switch-verify-revoke
S6	Activepieces Connection	encrypted-connection-store-and-provider-reauthorization

책임 경계

주체	책임
제품 책임자	Secret 유형, 보존·교체 정책과 고객 제공 방식 승인
TechFlow 운영자	생성·주입·교체·폐기, 접근 통제와 사고 대응
TechFlow Core	향후 Secret 참조 ID, 정책, 승인과 감사
Activepieces	Connection 암호화와 Flow 실행 · 제품 Secret 원장 아님
Event Gateway	현재·직전 Webhook Secret 검증과 Grace Period
외부 제공자	API Token과 자격증명의 최종 발급·폐기 권위

3. 저장·주입·감사 구조

요소	기준
보호 디렉터리	/etc/ablestack-techflow/secrets · root:ablecloud 0750
보호 파일	activepieces.env · root:ablecloud 0640
런타임 연결	배포 .env Symlink → 보호 파일 → Compose env_file
변경 도구	secretctl.sh + secret_env.py 원자적 갱신
감사	/var/log/ablestack-techflow/secret-audit.jsonl · 실제 값 없음
노출 검사	실제 값 완전 일치 검사 · 변수 이름과 건수만 출력
일반 백업	.env-보호 저장소-감사 로그 제외

주입 원칙

- Secret은 명령행 인자로 전달하지 않고 HMAC 도구는 표준입력을 사용한다.
- Flow JSON, GitHub Issue, 보고서와 일반 로그에는 값 또는 파생 서명을 기록하지 않는다.
- 자동 검사는 실제 값을 메모리에서 읽지만 출력에는 변수 이름과 노출 건수만 남긴다.

감사 Event

store.bootstrap, rotate.prepare, rotate.revoke_previous, rotate.lifecycle_test가 기록되었다. 필드는 time, actor, action, target, result로 제한한다.

4. Webhook Secret 수명주기

Current → Current + Previous → 발신자 전환 → Previous 폐기

단계	동작	성공 기준
준비	신규 Current 생성 · 기존 Current를 Previous로 이동	Previous가 이미 있으면 거부
Grace	Current와 Previous 동시 검증	각 요청 202
전환	발신 시스템을 신규 Current로 변경	정상 수신 확인
폐기	Previous 제거 후 Gateway만 재생성	Current 202 · Retired 401
롤백	유출이 없고 전환 실패 시 기존 값 복구	정상 수신 재검증
사고	유출 값은 Grace 없이 즉시 폐기	세션·Token·연결 무효화

영향 제한

- 교체는 Event Gateway 컨테이너만 재생성한다.
- Redis 컨테이너 ID가 교체 전후 동일함을 검증했다.
- 세 번째 Secret은 허용하지 않아 장기 Grace 상태를 방지한다.

5. 통합 검증

ID	검증	수치	결과
V1	protected store migration		PASS
V2	store directory and audit permissions		PASS
V3	required secret inventory	6	PASS
V4	event gateway unit tests	6/6	PASS
V5	current secret during grace	202	PASS
V6	previous secret during grace	202	PASS
V7	current secret after revoke	202	PASS
V8	retired secret after revoke	401	PASS
V9	gateway-only restart		PASS
V10	deployment asset secret exposure	0	PASS
V11	container log secret exposure	0	PASS
V12	HTTPS and signed webhook regression		PASS
V13	service restart recovery		PASS
V14	host reboot recovery	2026-07-31 04:37:24	PASS
V15	new general backup excludes runtime env		PASS

V1-V15 전체 PASS. 정상 교체뿐 아니라 폐기, 영향 제한, 실제 값 노출 0건과 재부팅 복구까지 확인했다.

6. 백업·사고 대응

일반 백업과 Secret 복구본은 분리한다.

항목	판정
Issue #15 신규 일반 백업	.env 제외 PASS
Issue #14 기존 Archive	root 전용 0700 디렉터리, 0600 파일로 격리
외부 암호화 Secret 복구본	Issue #16에서 저장 위치·보존·복원 훈련 확정
일반 데이터 복구	PostgreSQL-Redis 격리 복구 훈련은 Issue #16

사고 대응 순서

- 영향 Secret과 서비스를 분류하고 신규 값 발급 또는 강제 교체를 시작한다.
- 유출 값은 Grace Period 없이 즉시 폐기하고 세션·Token·Connection을 무효화한다.
- 실제 값 비노출 방식으로 저장소, Flow, 실행 기록과 로그를 검사한다.
- Health, Webhook 판정과 권위 시스템 상태를 다시 검증한다.
- 실제 값 없이 사고 시각, 영향, 조치와 후속 Issue를 기록한다.

7. 완료 판정과 다음 단계

최종 판정: VALIDATED. Issue #15를 종료하고 Issue #16 백업·복구 훈련으로 진행한다.

완료 기준	결과
Git-Issue·로그 비노출 기준	PASS
보호 저장소·런타임 주입	PASS
현재·직전 Grace Period와 폐기	PASS
변경 감사와 사고 대응	PASS
저장소·로그 실제 값 노출	0건
서비스 재시작·호스트 재부팅	PASS
ADR·Runbook·JSON·PDF·PPTX·Manifest	자산화 완료

후속 실행 순서

- Issue #16: PostgreSQL-Redis 백업과 격리 복구 훈련
- Issue #17-#18: 로그·메트릭·경보와 버전·회귀 정책
- Issue #19: GitHub PR Merge Webhook 기반 첫 업무 자동화 Flow
- 제품 확장: TechFlow Secret Provider와 Vault-KMS 연계

작성 기준: ADR-0002, Secret 수명주기 Runbook, 구조화 검증 JSON과 실제 서버 검증 결과.